# Password Cracking with Linux

*CSCI 352 Semester Project*

*Whitney Carpenter | Jacob Nagle | Andrew Taylor*

# What is “Password Cracking”

- The act of recovering or guessing a password used to protect a computer, user account, or sensitive data
- It can be performed ethically, such as during penetration testing or legitimate attempts to recover access to a device
- It can also be used unethically to gain unauthorized access to systems, often as part of a cyberattack

# Most Common ways of Password attacks

- Dictionary Attack - Uses a list of commonly used passwords to try and gain access to a system. It relies on the assumption that users often choose weak or predictable passwords.
- Brute-force Attack - Tries every possible combination of characters until the correct password is found.
- Credential Stuffing -  An attack where stolen username and password pairs from one breach are used to try and log into other accounts, exploiting password reuse.
- Password Spraying - Instead of trying many passwords on one account, this method tries one commonly used password across many accounts. It's designed to avoid triggering account lockouts due to repeated failed attempts.

# How are passwords stored on a computer?

# Windows

- When a password is created, Windows generates a hash of the password using the NT LAN Manager hash algorithm
- The generated hash is then encrypted using a key from the system boot key (syskey)
- The encrypted hash is stored within the Security Accounts Manager (SAM) file

# Linux

- When a password is created, Linux hashes it using your distributions configured hashing algorithm (SHA-512, bcrypt, etc)
- The password has a random salt added to it before it is hashed so that identical passwords can produce unique hashes
- The generated salted hash is stored in the /etc/shadow file which is only accessible by the root user (admin)

# What is a hash?

- In the context of security and computer storage, a hash algorithm takes data like a password and generates a fixed-length string of numbers called a hash value.
- The same input (passwords) will produce the same hash-values which is why additional security like salting and encryption is necessary.
- Salting is a process where a random string of characters called the salt, are added to the input before hashing.
- Common hashing algorithms – NT Hash, Kerberos, SHA-512, bcrypt, yescrypt

# Tools you will be using in the lab

- Kali
- DVL
- John the Ripper
- Hashcat
- Johnny

# Kali

- An open-source distribution of Linux geared towards Information Security
- Focus on effective penetration testing.
- Useful for practicing offensive and defensive tactics such as; vulnerability testing, computer forensics, and red team testing

# DVL

- Also known as “Damn Vulnerable Linux”
- Linux distribution geared towards helping students practice cyber security principles
- Like the name suggests, it is designed deliberately to be vulnerable to attack

# John The Ripper, Hashcat & Johnny

- John The Ripper & Hashcat– Password recovery command-line tools used for cracking password hashes
  - Uses a variety of attacks to obtain the password: dictionary attacks, brute-force, etc.
  - Can crack hashes produced by many different algorithms including SHA-512, bcrypt, etc.
- Johnny -  A GUI for John The Ripper
  - Lets you easily load hash files, adjust cracking settings, and view cracked passwords without having to use the command line.